

AgentGuard

Plataforma de autorización contextual y gobernanza en tiempo de ejecución para agentes de IA

Versión 2.0 — Propuesta reformulada y validada

6 de septiembre de 2026

INFORME DE PROPUESTA — DESARROLLO WEB

Resumen ejecutivo

AgentGuard propone una capa de control independiente del modelo y del proveedor de IA para autorizar, bloquear, aprobar y auditar las acciones que ejecutan agentes de inteligencia artificial sobre herramientas y sistemas empresariales. La propuesta parte de la idea original del equipo —identidad, permisos, API Gateway, simulación, bloqueo y auditoría— pero modifica su centro de gravedad: el valor diferencial ya no es simplemente administrar agentes, sino decidir si una acción concreta puede ejecutarse en un contexto concreto.

La formulación central es: «IAM responde quién eres; AgentGuard decide qué puedes hacer ahora». La plataforma modela al menos cinco elementos de cada decisión: identidad del agente, usuario o principal en cuyo nombre actúa, acción solicitada, recurso afectado y contexto de ejecución. El resultado puede ser ALLOW, DENY o REQUIRE_APPROVAL.

La reformulación es importante porque la categoría ya cuenta con soluciones comerciales de grandes proveedores y startups. Microsoft Entra Agent ID y Amazon Bedrock AgentCore Identity cubren identidad, autenticación, autorización y gobierno de agentes; Noma Security y Zenity compiten en seguridad y gobernanza de agentes; y la Cloud Security Alliance documenta explícitamente la necesidad de controles de identidad, least privilege, delegación, autorización contextual y observabilidad. [1][2][3][4][5]

Por lo tanto, este proyecto no debe defenderse como una tecnología inexistente en el mercado. Debe defenderse como un proyecto académico técnicamente fundamentado que implementa una arquitectura concreta de autorización contextual y enforcement en runtime, inicialmente enfocada en MCP, con un entorno de simulación que permite demostrar de forma verificable qué acciones son permitidas, bloqueadas o requieren intervención humana.

1. Antecedentes y punto de partida del equipo

El documento original de AgentGuard identifica como problema la creciente capacidad de los agentes de IA para consultar información, utilizar APIs, modificar registros, enviar comunicaciones y ejecutar procesos, y propone una plataforma de gestión, autorización y auditoría. También plantea un MVP con organizaciones, usuarios, agentes, políticas, API Gateway, simulación, logs, bloqueo, dashboard y alertas. [0]

La reformulación conserva estos componentes cuando aportan valor, pero evita convertirlos en el argumento principal. El gateway pasa a ser el punto de enforcement; la auditoría pasa a representar trazas de ejecución; la simulación se convierte en un AgentGuard Playground; y las políticas evolucionan desde permisos estáticos hacia decisiones contextuales.

2. Problema de negocio y técnico

Un agente de IA no se limita a generar texto: puede elegir herramientas, consultar datos, modificar recursos y encadenar acciones. Esto crea una frontera de seguridad distinta de la de una aplicación tradicional. OWASP identifica entre los riesgos principales de las aplicaciones agentic el goal hijack, tool misuse e identity & privilege abuse; además, describe excessive agency como un problema asociado a funcionalidad, permisos o autonomía excesivos. [6][7]

La Cloud Security Alliance aporta evidencia operacional. En un estudio publicado en 2026, el 53% de las organizaciones encuestadas reportó que sus agentes habían excedido los permisos previstos y el 47% informó un incidente de seguridad relacionado con un agente durante el año anterior. El estudio también encontró baja confianza en la capacidad de detectar amenazas específicas de agentes. [8]

Otro estudio de CSA, realizado con 228 profesionales de IT y seguridad, informó que el 68% de las organizaciones no podía distinguir claramente las acciones de agentes de las humanas y señaló problemas de credenciales, ownership y controles de acceso. [9]

El problema que AgentGuard pretende abordar, por tanto, no es hipotético. La necesidad está siendo tratada por estándares, organismos de seguridad, hyperscalers y empresas especializadas.

3. Insight central: autorización de la acción, no solo identidad

La pregunta clásica de IAM es: «¿quién es el actor y qué permisos posee?». En un sistema agentic la pregunta debe ampliarse: «¿este actor puede ejecutar esta acción, sobre este recurso, para este usuario, dentro de esta tarea y bajo estas condiciones?».

Modelo conceptual de decisión:

- Principal: agente que solicita la operación.
- Delegator/User: usuario, sistema o agente superior en cuyo nombre se realiza la operación.
- Action: operación concreta, por ejemplo create_quote, refund, delete_customer o update_price.
- Resource: recurso afectado, por ejemplo customer/4589.
- Context: horario, importe, origen, riesgo, tarea, sesión, entorno y otras condiciones.
- Policy: conjunto de reglas que determina la decisión.
- Decision: ALLOW, DENY o REQUIRE_APPROVAL.
- Trace: evidencia inmutable o altamente protegida de la decisión y de la ejecución.

Este modelo coincide con líneas de trabajo recientes de la Cloud Security Alliance, que señalan la necesidad de permisos fine-grained, específicos de recursos y sensibles al contexto, además de delegación explícita y least privilege para agentes. [3]

4. Propuesta de producto reformulada

Nombre: AgentGuard. Posicionamiento: Runtime Authorization & Governance for AI Agents.

Propuesta de valor: «AgentGuard permite a las organizaciones dar autonomía a sus agentes de IA sin darles carta blanca. Intercepta las acciones hacia herramientas y recursos, evalúa políticas contextuales, bloquea operaciones no autorizadas, solicita aprobación humana cuando corresponde y mantiene una trazabilidad completa de la ejecución».

Principios de diseño:

- Least privilege: cada agente recibe únicamente las capacidades necesarias.
- Never trust the model as the enforcement point: el LLM puede proponer una acción, pero no decide por sí mismo si está autorizada.
- Policy outside the agent: las políticas se ejecutan fuera del modelo y de forma determinista en el MVP.
- Context-aware authorization: una misma herramienta puede estar permitida en un contexto y bloqueada en otro.
- Human-in-the-loop: operaciones sensibles pueden requerir aprobación.
- Auditability: toda decisión relevante produce una traza consultable.
- Provider agnostic: el diseño no depende de un único proveedor de modelo.
- Standards-first: MCP/OAuth se toma como primera superficie de integración en lugar de inventar un protocolo propio.

5. Validación de necesidad y señales de mercado

Señal	Evidencia	Implicación para AgentGuard
Riesgo reconocido	OWASP 2026 identifica Tool Misuse, Identity & Privilege Abuse y Excessive Agency.	Existe una categoría de riesgo reconocida y documentada.
Incidentes reales	CSA reportó 47% de organizaciones con un incidente relacionado con agentes en su encuesta de 2025/2026.	La seguridad de agentes ya es un problema operacional.
Violaciones de scope	CSA reportó 53% de organizaciones con agentes que excedieron permisos previstos.	Justifica enforcement en runtime y least privilege.
Problema de atribución	CSA reportó 68% sin capacidad clara para distinguir actividad de agentes y humanos.	Justifica identidad, delegación y trazabilidad.
Oferta enterprise	Microsoft Entra Agent ID ofrece identidad, gobierno y protección de agentes.	Valida la categoría, pero obliga a diferenciarse.
Oferta cloud	AWS Bedrock AgentCore Identity ofrece identidad, autenticación, autorización y credenciales para agentes.	Confirma que la infraestructura de identidad agentic es un mercado real.

Señal	Evidencia	Implicación para AgentGuard
Inversión especializada	Noma anunció USD 100M de Series B; Zenity anunció USD 125M de Series C en 2026.	Existe inversión significativa en seguridad/gobernanza de agentes.

6. Análisis competitivo

Actor / tecnología	Fortaleza	Qué NO debemos prometer que somos	Espacio para AgentGuard
Microsoft Entra Agent ID	Identidad, acceso, gobierno, lifecycle y controles de seguridad para agentes.	Un reemplazo de Entra.	Capa independiente para decisiones de acción y simulación; especialmente útil como proyecto interoperable.
AWS Bedrock AgentCore Identity	Identidad, credenciales, OAuth, autorización y acceso a recursos.	Un reemplazo de IAM/AgentCore.	Policy enforcement y playground conceptualmente agnóstico del proveedor.
Noma Security	Plataforma amplia de AI/agent security, posture y runtime control.	Una suite enterprise completa.	MVP académico focalizado en authorization gateway + policy + approval + trace.
Zenity	Gobernanza, observabilidad y seguridad específica de agentes.	Una plataforma de AI security de escala enterprise.	Implementación acotada, explicable y demostrable del enforcement.
OPA / Cedar / motores de policy	Motores sólidos para autorización.	Un motor de políticas completamente nuevo.	Usarlos como referencia o incluso como componente futuro; AgentGuard aporta dominio, runtime y UX.
MCP	Protocolo con mecanismos de autorización basados en OAuth.	Un protocolo propietario.	AgentGuard como enforcement/policy layer alrededor de MCP.

La competencia no invalida el proyecto. Al contrario: demuestra que existe una categoría. La consecuencia estratégica es que AgentGuard debe ser explícito respecto de su alcance y no afirmar originalidad absoluta.

7. Diferenciación propuesta

La diferenciación académica y potencialmente comercial se apoya en cinco elementos integrados:

- Autorización contextual por acción: no basta con que el agente posea una herramienta; se evalúa la operación concreta.
- Delegación trazable: la decisión conserva la relación usuario → agente → tarea → herramienta → recurso.
- Enforcement externo al modelo: una prompt injection puede influir en la decisión del agente, pero no puede concederle permisos que AgentGuard no le otorgó.
- Aprobación humana como resultado de política, no como parche manual.
- Playground de simulación y explicación de decisiones: permite probar escenarios seguros y demostrar por qué una acción fue permitida o bloqueada.

La formulación de seguridad es particularmente importante: si el agente está comprometido, la frontera de seguridad debe permanecer fuera del LLM. Investigaciones recientes sobre autorización de agentes señalan precisamente la necesidad de no confiar en que el propio agente haga cumplir sus límites y estudian brokers de autorización externos para contener delegaciones y privilege escalation. [10]

8. Casos de uso

8.1 Agente de ventas

Puede consultar clientes, consultar productos y crear presupuestos. No puede modificar precios ni eliminar clientes.

8.2 Agente financiero

Puede preparar una devolución, pero cualquier operación superior a un umbral requiere aprobación de un responsable.

8.3 Agente de soporte

Puede leer tickets y responderlos; no puede borrar tickets ni modificar datos sensibles del cliente.

8.4 Agente de RR.HH.

Puede consultar información autorizada para una tarea, pero se bloquea el acceso a atributos sensibles fuera de alcance.

8.5 Prompt injection

Un documento o email intenta inducir al agente a exportar una base de clientes. AgentGuard evalúa la acción solicitada y la bloquea aunque el agente haya sido manipulado.

8.6 Privilege escalation

Un agente intenta invocar una herramienta no incluida en su capability set. La petición es rechazada y auditada.

8.7 Acción fuera de contexto

Una herramienta está permitida, pero la política impide su uso fuera de horario, fuera de una organización o sobre recursos de alta sensibilidad.

9. Demo principal recomendada

La presentación al profesor debe evitar una demo basada únicamente en CRUD. Se recomienda una secuencia de cuatro decisiones sobre la misma organización y el mismo agente:

Escenario	Solicitud	Resultado	Por qué
1. Operación normal	create_quote por USD 2.500	ALLOW	La política de ventas permite la operación bajo el umbral.
2. Operación prohibida	update_price	DENY	El agente no tiene capacidad para modificar precios.
3. Operación sensible	refund por USD 4.500	REQUIRE_APPROVAL	La política exige intervención humana por encima del umbral.
4. Prompt injection	export_customers hacia destino externo	DENY + ALERT	La acción está fuera del propósito/capability autorizado y se registra como intento de violación.

Después se muestra el Execution Trace: usuario, agente, tarea, herramienta, recurso, política aplicada, decisión, timestamp, riesgo y eventual aprobación. Esta secuencia demuestra seguridad, backend, frontend, persistencia, reglas de negocio, API y UX en una sola experiencia.

10. Arquitectura propuesta

Arquitectura lógica:

- Frontend Web: dashboard de agentes, herramientas, políticas, ejecuciones, alertas y aprobaciones.
- API / Backend: gestión multi-tenant, autenticación, autorización de administración y API de runtime.
- Agent Runtime Gateway: punto de entrada de las llamadas de herramientas.
- Policy Decision Point (PDP): evalúa principal, delegator, action, resource y context.
- Policy Enforcement Point (PEP): intercepta la solicitud y ejecuta ALLOW/DENY/REQUIRE_APPROVAL.

- Approval Service: gestiona operaciones pendientes y decisiones humanas.
- Audit Service: almacena Execution Traces y eventos.
- Tool Connectors: inicialmente mock/REST y posteriormente MCP.
- Database: organizaciones, usuarios, agentes, tools, policies, executions, approvals y alerts.

Flujo de ejecución: Agent/Client → AgentGuard Gateway → autenticación/validación → extracción de contexto → Policy Decision → ALLOW/DENY/REQUIRE_APPROVAL → Tool/MCP Server → resultado → Audit Trace.

MCP es un buen primer protocolo de integración porque su especificación actual define mecanismos de autorización basados en OAuth 2.1, Protected Resource Metadata y discovery del authorization server. [11]

11. Modelo de datos mínimo

Entidad	Responsabilidad
Organization	Tenant y límites de aislamiento.
User	Usuario administrativo/operador/approver.
Agent	Identidad, owner, propósito, estado y capacidades.
Tool	Herramienta y acciones que expone.
Policy	Regla de autorización.
PolicyRule	Condiciones y resultado de una política.
Execution	Solicitud de acción y decisión.
Approval	Solicitud de intervención humana.
Alert	Evento de riesgo o violación.
AuditEvent	Registro de eventos administrativos y de runtime.

12. Ejemplo de política

La sintaxis exacta queda a definir durante el desarrollo. Conceptualmente, una política podría expresarse como:

ALLOW create_quote WHEN agent.role = sales AND amount < 10000

REQUIRE_APPROVAL refund WHEN amount >= 500

DENY update_price FOR agent.sales

DENY export_customers WHEN destination is external

Para el MVP se recomienda una DSL sencilla o JSON/YAML validado. En una evolución futura se puede estudiar integración con OPA, Cedar u otro policy engine, evitando reinventar innecesariamente la teoría de autorización.

13. MVP académico

Módulo	Alcance MVP	Prioridad
Multi-tenancy	Organization + usuarios + aislamiento básico.	P0
Agent Registry	Alta, baja, estado, owner y capabilities.	P0
Tool Registry	Registro de tools/actions/resources.	P0
Policy Engine	ALLOW / DENY / REQUIRE_APPROVAL + condiciones.	P0
Runtime Gateway	Endpoint para evaluar y enrutar tool calls.	P0
Execution Trace	Registro de request, decision y resultado.	P0
Approval Workflow	Bandeja y decisión humana.	P1

Módulo	Alcance MVP	Prioridad
Dashboard	Métricas, ejecuciones, bloqueos, approvals.	P1
Simulator / Playground	Escenarios reproducibles.	P1
Alerts	Reglas deterministas de riesgo.	P1
MCP adapter	Primer conector estándar.	P1
ML anomaly detection	No incluido en MVP.	P2

Decisión de alcance: no se recomienda implementar machine learning para detección de anomalías en la primera versión. Las alertas del MVP deben ser deterministas y explicables. Esto reduce riesgo técnico y mejora la defendibilidad académica.

14. Requisitos funcionales

- RF-01: registrar organizaciones y usuarios.
- RF-02: registrar agentes y asignar owner.
- RF-03: registrar herramientas y acciones.
- RF-04: definir políticas con condiciones.
- RF-05: evaluar una solicitud de acción.
- RF-06: devolver ALLOW, DENY o REQUIRE_APPROVAL.
- RF-07: impedir que una solicitud DENY alcance la herramienta protegida.
- RF-08: crear y resolver solicitudes de aprobación.
- RF-09: almacenar una Execution Trace por solicitud.
- RF-10: consultar historial y filtrar por agente, usuario, herramienta, decisión y fecha.
- RF-11: generar alertas por reglas configuradas.
- RF-12: ejecutar escenarios en el Playground.

15. Requisitos no funcionales

- Seguridad: autenticación robusta, secretos fuera del código, validación de entradas y aislamiento por organización.
- Trazabilidad: cada decisión debe ser correlacionable mediante un request/execution ID.
- Determinismo: el Policy Engine del MVP no debe depender de una respuesta generativa para decidir ALLOW/DENY.
- Disponibilidad: el gateway no debe convertirse en un single point of failure sin estrategia de fallback definida.
- Observabilidad: métricas, logs técnicos y trazas funcionales separadas.
- Privacidad: evitar registrar secretos o payloads sensibles innecesarios.
- Extensibilidad: separar policy engine, gateway y adapters.
- Testabilidad: escenarios de autorización reproducibles y tests de políticas.

16. Roadmap de evolución

Fase	Objetivo	Capacidades
V0 — Academic MVP	Probar el concepto.	Agents, tools, policies, gateway, traces, dashboard, simulator.
V1 — MCP Gateway	Integración estándar.	MCP adapter, OAuth integration, tool discovery, scopes.
V2 — Contextual Authorization	Autorizar según contexto.	Usuario, tarea, recurso, horario, importe, sensibilidad, environment.

Fase	Objetivo	Capacidades
V3 — Human-in-the-loop	Controlar operaciones críticas.	Approvals, escalation, expiration, separation of duties.
V4 — Behavioral Guard	Comparar acción vs. propósito.	Risk scoring, sequence analysis, off-task detection.
V5 — Agent Governance	Escalar a organizaciones.	Inventory, posture, lifecycle, owner/sponsor, policy templates.
V6 — Enterprise	Producto comercial.	SSO, SIEM, compliance exports, HA, multi-region, integrations.

17. Modelo de negocio propuesto

La propuesta comercial es SaaS B2B, pero los precios deben considerarse hipótesis a validar, no referencias de mercado. La unidad de valor podría combinar número de agentes, volumen de ejecuciones, retención de trazas e integraciones.

Plan conceptual	Cliente	Características
Free / Playground	Desarrolladores / estudiantes	Simulador, agentes y políticas limitadas.
Developer	Pequeños equipos	Gateway, trazas, integraciones básicas.
Team	Startups / equipos de producto	Multi-user, approvals, retención mayor, alertas.
Business	Empresas medianas	SSO, más integraciones, políticas avanzadas, exportación.
Enterprise	Organizaciones grandes	Alta disponibilidad, soporte, compliance, SIEM y despliegue dedicado.

El argumento de ROI no debe ser «ahorrar dinero en logs». Debe ser «permitir desplegar agentes con más autonomía sin aceptar privilegios indiscriminados». El valor aparece cuando una empresa puede pasar de agentes experimentales a agentes operativos porque existe una frontera de seguridad verificable.

18. Validación comercial antes de convertirlo en startup

La evidencia de mercado justifica explorar el producto, pero no demuestra product-market fit. Para validar la oportunidad se propone entrevistar al menos a 5–10 perfiles técnicos o de seguridad y probar hipótesis con una demo funcional.

- ¿Cuántos agentes tienen en producción o piloto?
- ¿Qué herramientas pueden invocar?
- ¿Usan credenciales compartidas o identidades individuales?
- ¿Cómo restringen acciones de alto impacto?
- ¿Cómo distinguen una acción del agente de una acción humana?
- ¿Cómo investigan por qué un agente hizo algo?
- ¿Qué operaciones requieren aprobación?
- ¿Qué producto utilizan hoy para resolverlo?
- ¿Qué parte de la solución comprarían y cuánto valor tendría evitar un incidente o acelerar un despliegue?

El criterio de validación no debe ser que al entrevistado «le guste la idea». Debe existir un problema actual, una solución alternativa identificable y disposición a invertir tiempo, presupuesto o integración.

19. Riesgos y mitigaciones

Riesgo	Impacto	Mitigación
Scope creep	Alto	MCP + mock tools como alcance inicial; no soportar todos los frameworks.
Competencia enterprise	Alto	No competir por IAM general; focalizar en enforcement contextual y demo académica.
Complejidad de seguridad	Alto	Modelo determinista, tests y amenazas explícitas.
Dependencia de IA generativa	Medio	Policy engine fuera del LLM.
Latencia del gateway	Medio	Políticas simples, caché cuando sea seguro y medición.
Falsos positivos	Medio	En MVP usar reglas transparentes y aprobación humana.
Datos sensibles	Alto	No almacenar payloads completos por defecto; minimización y masking.
MCP cambia rápidamente	Medio	Adapter desacoplado y versión documentada del protocolo.

20. Seguridad: modelo de amenaza resumido

Threats prioritarias:

- Prompt injection que intenta cambiar el objetivo del agente.
- Tool misuse: utilización de una herramienta legítima para una finalidad no autorizada.
- Privilege escalation: intento de utilizar capacidades fuera del capability set.
- Credential theft/replay.
- Confused deputy: un agente utiliza permisos otorgados en nombre de otro principal de forma indebida.
- Compromiso de una herramienta o servidor MCP.
- Abuso de un sub-agente dentro de una cadena de delegación.
- Falta de trazabilidad que impida atribuir una operación.

La arquitectura propuesta responde a estos riesgos colocando la decisión de autorización fuera del modelo, usando least privilege, identificando al agente y al delegador, y registrando la cadena de decisión. Esto se alinea con la literatura reciente sobre authorization brokers y runtime governance para agentes. [3][10]

21. Defensa frente al profesor: preguntas difíciles

¿No es simplemente un API Gateway?

No. El gateway es el mecanismo de enforcement. El producto decide sobre una acción de un agente considerando identidad, delegación, recurso, contexto y política; además gestiona aprobación y trazabilidad.

¿No existe Microsoft Entra Agent ID?

Sí. La propuesta no debe negar eso. Entra valida la categoría. AgentGuard es un proyecto académico focalizado en authorization de acciones y puede coexistir con IAM en lugar de reemplazarlo.

¿Por qué no usar AWS IAM?

IAM resuelve una parte del problema. AgentGuard modela el dominio de acciones de agentes y puede usar proveedores de identidad existentes.

¿Por qué no usar OPA?

OPA es un excelente policy engine. AgentGuard puede integrarlo en una evolución futura; el valor del proyecto está en el dominio, gateway, workflow, trazabilidad y UX.

¿Qué tiene de web?

Es una aplicación web multi-tenant con frontend, backend REST, autenticación, persistencia, autorización, eventos, dashboard y un gateway de runtime.

¿Dónde está la IA?

El sistema protege agentes de IA y puede integrar agentes reales; el MVP no necesita construir un modelo propio. La IA es el actor que propone acciones, mientras AgentGuard garantiza los límites.

¿Cómo demuestran que funciona?

Con escenarios reproducibles: ALLOW, DENY, REQUIRE_APPROVAL y prompt injection bloqueada, mostrando la traza de decisión.

¿Es realmente comercializable?

Existe una categoría comercial demostrada por productos e inversiones actuales. La comercialización concreta sigue siendo una hipótesis y se propone validarla mediante entrevistas y pilotos.

¿Por qué MCP?

Es un estándar relevante para conectar agentes con herramientas y ya dispone de mecanismos de autorización basados en OAuth; permite acotar el alcance técnico y evitar inventar un protocolo.

22. Criterios de éxito del proyecto

- Un administrador puede registrar un agente y sus herramientas.
- Una política puede expresarse y modificarse desde la aplicación.
- Una tool call pasa por AgentGuard antes de llegar al recurso protegido.
- Una acción prohibida nunca alcanza la tool protegida.
- Una acción sensible queda pendiente de aprobación.
- Todas las decisiones generan una traza consultable.
- El dashboard permite explicar por qué una acción fue permitida o bloqueada.
- Los escenarios del Playground son reproducibles mediante tests automatizados.
- El sistema mantiene aislamiento entre organizaciones.
- La documentación explica claramente límites, amenazas y decisiones arquitectónicas.

23. Plan de implementación sugerido

Sprint	Objetivo	Entregable demostrable
Sprint 0	Arquitectura y diseño	Modelo de dominio, ADRs, wireframes, repo, CI.
Sprint 1	Identity & tenancy	Login, organizations, users, agents.
Sprint 2	Tools & policies	Registro de tools y policy CRUD.
Sprint 3	Runtime Gateway	Evaluación ALLOW/DENY y bloqueo efectivo.
Sprint 4	Audit & dashboard	Execution traces y dashboard.
Sprint 5	Approvals & alerts	REQUIRE_APPROVAL y alertas deterministas.
Sprint 6	Playground + hardening	Escenarios de ataque, tests, documentación y demo final.

24. Conclusión

AgentGuard es una propuesta viable para Desarrollo Web y, correctamente reformulada, puede defenderse como un proyecto de ingeniería serio y no como un CRUD con IA de moda. El problema está respaldado por OWASP, CSA y por la aparición de productos especializados de Microsoft, AWS, Noma, Zenity y otros actores. [1][2][4][5][6][8][9]

La principal condición para que la propuesta sea sólida es aceptar el estado real del mercado. No se debe afirmar que AgentGuard inventa la seguridad de agentes ni que reemplaza IAM. Su aporte es construir una implementación focalizada de una arquitectura de autorización y gobernanza en runtime: una frontera externa al modelo que decide qué acción puede ejecutarse, bajo qué contexto, con qué aprobación y con qué evidencia.

La mejor defensa académica es, por tanto, doble: primero, existe un problema real y actual; segundo, el equipo ha reducido ese problema a un alcance web implementable, medible y demostrable. El MVP no pretende resolver toda la seguridad de agentes. Pretende demostrar de forma rigurosa una pieza crítica de esa arquitectura.

Frase de defensa recomendada: «No estamos construyendo otro chatbot ni otro IAM. Estamos construyendo una frontera de autorización para agentes: el agente puede proponer una acción, pero AgentGuard decide si tiene autoridad para ejecutarla.»

25. Referencias

[0] Documento base del equipo: AgentGuard – Control de Agentes de IA, Sprint 0 y propuesta inicial. Fuente entregada por el equipo.

[1] Microsoft Learn — Microsoft Entra Agent ID documentation.
<https://learn.microsoft.com/en-us/entra/agent-id/>

[2] Amazon Web Services — Amazon Bedrock AgentCore Identity.
<https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/identity.html>

[3] Cloud Security Alliance — Agentic AI Identity and Access Management: A New Approach (2025).
<https://cloudsecurityalliance.org/artifacts/agentic-ai-identity-and-access-management-a-new-approach>

[4] Noma Security — Noma Security raises \$100M Series B (2025).
<https://www.noma.security/blog/noma-security-raises-100m-to-drive-adoption-of-ai-agent-security>

[5] Zenity — Zenity raises \$125M Series C (2026).
<https://zenity.io/company-overview/newsroom/company-news/zenity-raises-125-million-to-secure-the-era-of-1-billion-ai-agents>

[6] OWASP GenAI Security Project — Top 10 for Agentic Applications 2026.
<https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

[7] OWASP — Excessive Agency / agentic security guidance.
<https://genai.owasp.org/llmrisk/llm06-sensitive-information-disclosure/>

[8] Cloud Security Alliance — More Than Half of Organizations Experience AI Agent Scope Violations (2026).
<https://cloudsecurityalliance.org/press-releases/2026/04/16/more-than-half-of-organizations-experience-ai-agent-scope-violations-cloud-security-alliance-study-finds>

[9] Cloud Security Alliance — Identity and Access Gaps in the Age of Autonomous AI (2026).
<https://cloudsecurityalliance.org/artifacts/identity-and-access-gaps-in-the-age-of-autonomous-ai>

[10] Dantuluri & Sundi — Delegation Without Trust: An Empirical Gap Analysis of Identity, Authorization, and Runtime Governance in Multi-Agent LLM Systems (2026).
<https://arxiv.org/abs/2609.00267>

[11] Model Context Protocol — Authorization specification.
<https://modelcontextprotocol.io/specification/2025-11-25/basic/authorization>

[12] Cloud Security Alliance — Securing Autonomous AI Agents (2026).
<https://cloudsecurityalliance.org/artifacts/securing-autonomous-ai-agents>

[13] Cloud Security Alliance — More Than Two-Thirds of Organizations Cannot Clearly Distinguish AI Agent from Human Actions (2026).
<https://cloudsecurityalliance.org/press-releases/2026/03/24/more-than-two-thirds-of-organizations-cannot-clearly-distinguish-ai-agent-from-human-actions>

26. Nota metodológica

Este informe combina el documento base entregado por el equipo con investigación web realizada para esta versión y refleja el estado consultado al 6 de septiembre de 2026. Las cifras de mercado y financiación se presentan como evidencia de actividad de la categoría, no como garantía de demanda para AgentGuard. Los precios sugeridos son hipótesis de posicionamiento y deben validarse con entrevistas. Las afirmaciones sobre productos competidores se limitan a las capacidades descritas en sus fuentes oficiales.